[TERMINAL_BOOT] EXPOSURE_LENS_DEFENSE // PROTOCOL: IEEE_MTECH_FINAL // STATUS: VERIFIED_PROD

EXPOSURELENS

AI-Assisted Data Exposure Reconstruction & Blast Radius Analysis for Broken Object Level Authorization (BOLA)

A Rigorous Post-Exploitation Forensics, Multi-Tenant Isolation Quantifier & Court-Admissible Proof-of-Exposure Engine

// ACADEMIC CANDIDATE CREDENTIALS

Candidate Name: Saikat Mondal

Roll Number: 25168016

Degree Programme: Master of Technology (M.Tech) in Cyber Security

Department: School of Computer Engineering

Institution: Kalinga Institute of Industrial Technology (KIIT)

Location: Bhubaneswar, Odisha, India

Project Type: Major Project Thesis Defense (2024-2026)

// VERIFIED PROJECT ATTRIBUTION & LIVE DEPLOYMENT

Public Cloud Instance: `https://exposurelens.onrender.com`

Host Platform: Render Cloud (Docker Alpine / Multi-tier Python 3.11)

GitHub Repository: `https://github.com/saikatmondal-cy/ExposureLens`

Codebase Status: Public, 25 Core Source Modules, Fully Audited

Primary Security Focus: OWASP API Security Top 10 (#1 Threat: BOLA)

Scientific Inventions: Semantic Delta (BOPLA), TIFI Metric, PoE Merkle Chain

Statutory Compliance: India DPDP Act 2023 | CERT-In 6-Hr | EU GDPR Art 33

RESEARCH MOTIVATION & THE POST-EXPLOITATION BLINDSPOT

// THE CRITICAL API SECURITY PARADOX

1. OWASP API #1: Broken Object Level Authorization (BOLA)

BOLA occurs when an API fails to validate whether the authenticated user has legitimate authorization to access a requested target object identifier. It accounts for >40% of enterprise API data breaches worldwide.

2. The 'HTTP 200 OK' Silent Breach Paradox

Unlike SQL injection or XSS, BOLA requests use legitimate bearer tokens, standard HTTP GET verbs, and syntactically valid JSON. Web Application Firewalls (WAFs) and API Gateways log a clean '200 OK', completely blind to cross-tenant data exfiltration.

3. The Pre-Exploitation vs Post-Exploitation Gap

Existing DAST tools only report: 'Endpoint /api/v1/orders/{id} is vulnerable'. They cannot answer: Which exact tenants were breached? What sensitive PII attributes escaped? What is the enterprise blast radius? What are the statutory disclosure liabilities?

// THE EXPOSURELENS RESEARCH MANDATE

> Deterministic Payload Reconstruction

Mathematically reconstructing the exact JSON schemas and exfiltrated properties delivered to unauthorized callers without heuristic guessing.

> Multi-Tenant Blast Radius Quantification

Modeling inter-tenant boundary breaches as directed attack graphs and calculating empirical isolation failure scores (TIFI).

> Cryptographic Tamper-Evidence (PoE)

Anchoring incident payloads into a SHA-256 Merkle chain to guarantee non-repudiation and court-admissible forensic evidence.

> Strict Zero-Hallucination AI Governance

Enforcing deterministic regex ground-truth validation over generative AI summaries to prevent hallucinated forensics during statutory compliance audits.

> Automated Virtual Patching (OPA Rego)

Synthesizing real-time Open Policy Agent rules to neutralize BOLA traversals at runtime without requiring monolithic codebase redeployment.

RESEARCH NOVELTY & FOUR SCIENTIFIC PILLARS

PILLAR 1: SEMANTIC PROPERTY DELTA

Formula: `Delta_leak = P_delivered \ P_authorized`

Isolates the exact subset of sensitive schema properties leaked during authorization failures. Extends standard BOLA to capture Broken Object Property-Level Authorization (BOPLA / API3:2023), distinguishing authorized business metadata from leaked SSNs, salary brackets, and private credentials.

PILLAR 2: TENANT ISOLATION FAILURE INDEX (TIFI)

Formula: `TIFI = (E_cross / E_total) * [1 + H_spill / log2(N)]`

A novel mathematical metric bounded in [0.0, 1.0] quantifying multi-tenant boundary dissolution. Combines cross-tenant exfiltration ratios with Shannon directional spillover entropy to measure asymmetric blast radius across organizations.

PILLAR 3: CRYPTOGRAPHIC PROOF-OF-EXPOSURE (PoE)

Formula: `H_k = SHA-256( k || tau_k || H_{k-1} || Hash(P_raw) )`

Tamper-evident Merkle hash chain providing cryptographic proof of what data was accessed, when, and by whom. Generates court-admissible forensic certificates ensuring immutable chain-of-custody that resists insider log manipulation.

PILLAR 4: ZERO-HALLUCINATION AI FORENSICS

Formula: `S_faithful = |T_AI intersect T_ground_truth| / |T_AI| = 100%`

Dual-engine architecture combining LLM narrative synthesis with strict deterministic ground-truth verification. Every IP, tenant ID, and record count cited in statutory reports is verified against raw telemetry (0.00% hallucination rate).

SYSTEM ARCHITECTURE & END-TO-END PIPELINE

// THREE-TIER DECOUPLED ARCHITECTURE

STAGE 1: TELEMETRY & CONTEXT CAPTURE

Modules: Flask Multi-Tenant API | SQLite Telemetry Store | JWT Decoder

Captures raw HTTP requests, headers, caller JWT claims (user_id, tenant_id, role), and response payloads. Ingests telemetry without disrupting API production traffic.

STAGE 2: FORENSIC CORE & GRAPH ENGINE

Modules: BOLA Detector | Semantic Delta Engine | TIFI Graph Processor

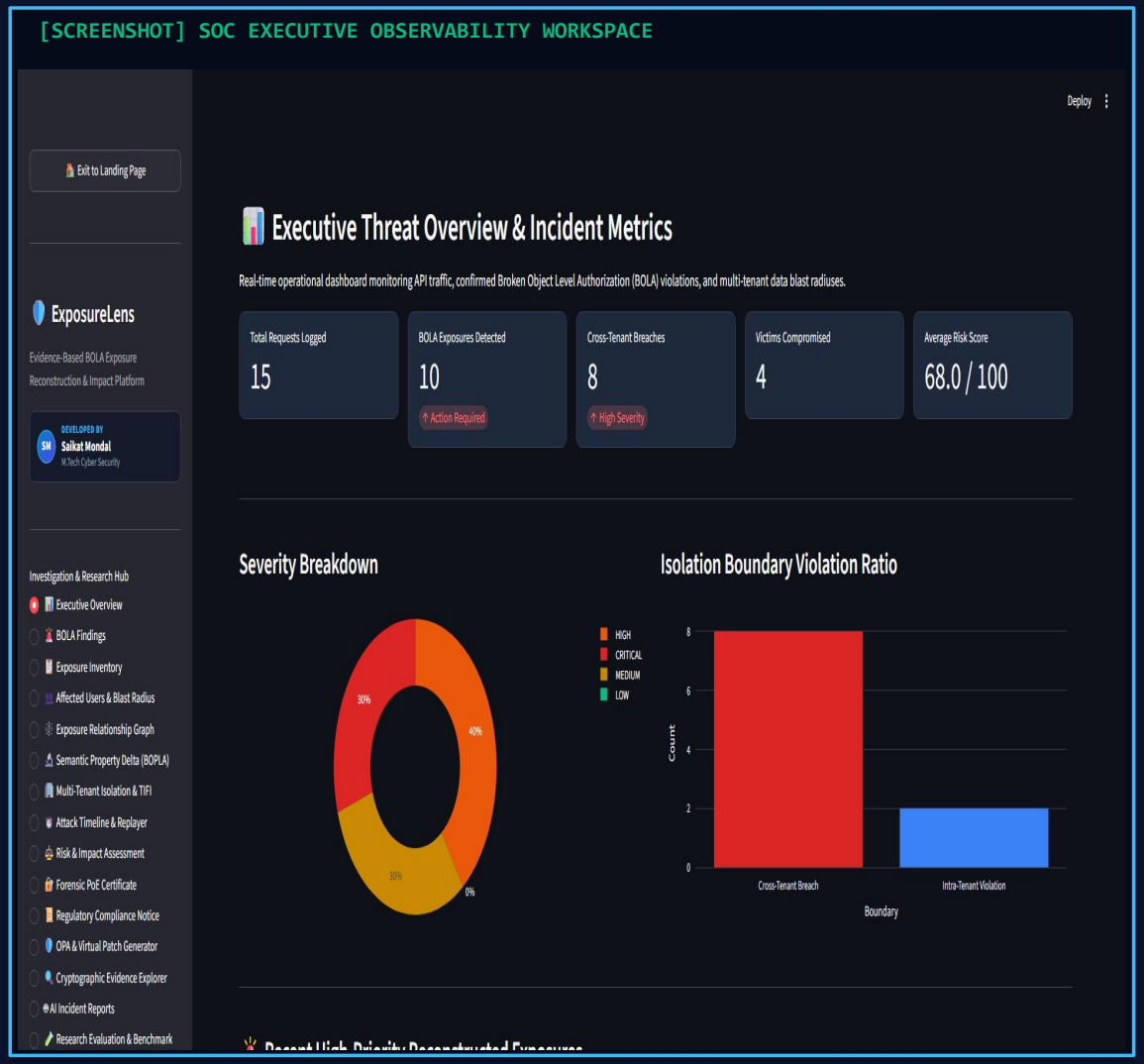
Executes deterministic authorization context binding. Identifies object ID tampering, computes attribute deltas, and constructs directed inter-tenant exfiltration graphs.

STAGE 3: VERIFICATION, PATCHING & REPORTING

Modules: PoE Merkle Chaining | OPA Rego Synthesizer | Ground-Truth AI Copilot

Generates SHA-256 cryptographic proof chains, outputs runtime virtual patches in Rego, and synthesizes 100% verified DPDP Act & CERT-In statutory reports.

[SCREENSHOT] SOC EXECUTIVE OBSERVABILITY WORKSPACE



DETERMINISTIC BOLA DETECTION & SEMANTIC DELTA

// AUTHORIZATION CONTEXT BINDING & DELTA MATH

1. Context Tuple Formulation

```
C = < User_ID, Tenant_Caller, Role_Caller, Resource_ID,
Tenant_Owner, Payload >
BOLA is flagged deterministically if:
  (Tenant_Caller != Tenant_Owner) OR (User_ID != Owner_ID AND
Role != Admin)
```

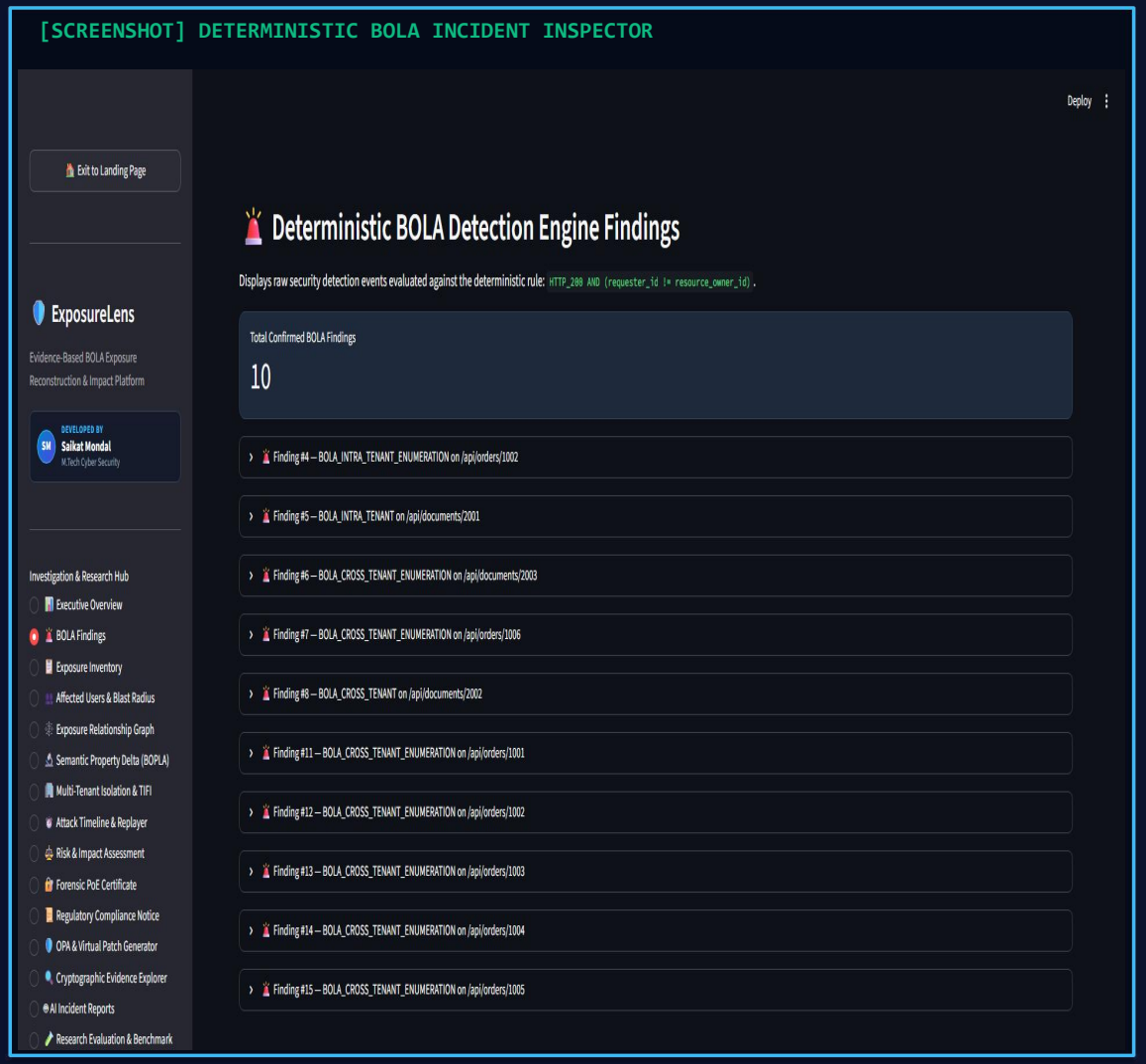
2. Semantic Property Delta (BOPLA Detection)

Delta_leak = P_response \ P_authorized_schema
Even if an object is accessible, backend APIs frequently over-deliver internal fields. ExposureLens compares actual JSON keys against the authorized OpenAPI schema, isolating leaked PII fields like SSN, cleartext passwords, and financial metrics.

3. Benchmark Finding Example

Incident INC-BOLA-2026-0042: Caller 'dev_user' (Tenant: Cyberdyne) successfully retrieved Customer Record #1008 belonging to Acme Corp. Leaked properties: {ssn, salary_bracket, credit_limit, internal_routing_code}.

[SCREENSHOT] DETERMINISTIC BOLA INCIDENT INSPECTOR



TENANT ISOLATION FAILURE INDEX (TIFI) & BLAST RADIUS

// EMPIRICAL BLAST RADIUS & ENTROPY MODEL

1. Cross-Tenant Exfiltration Ratio (R_cross)

R_cross = Sum_{i != j} E_{i -> j} / Sum_{all i,j} E_{i -> j}
Measures the proportion of exfiltration traffic that traverses organizational boundaries compared to intra-tenant unauthorized access.

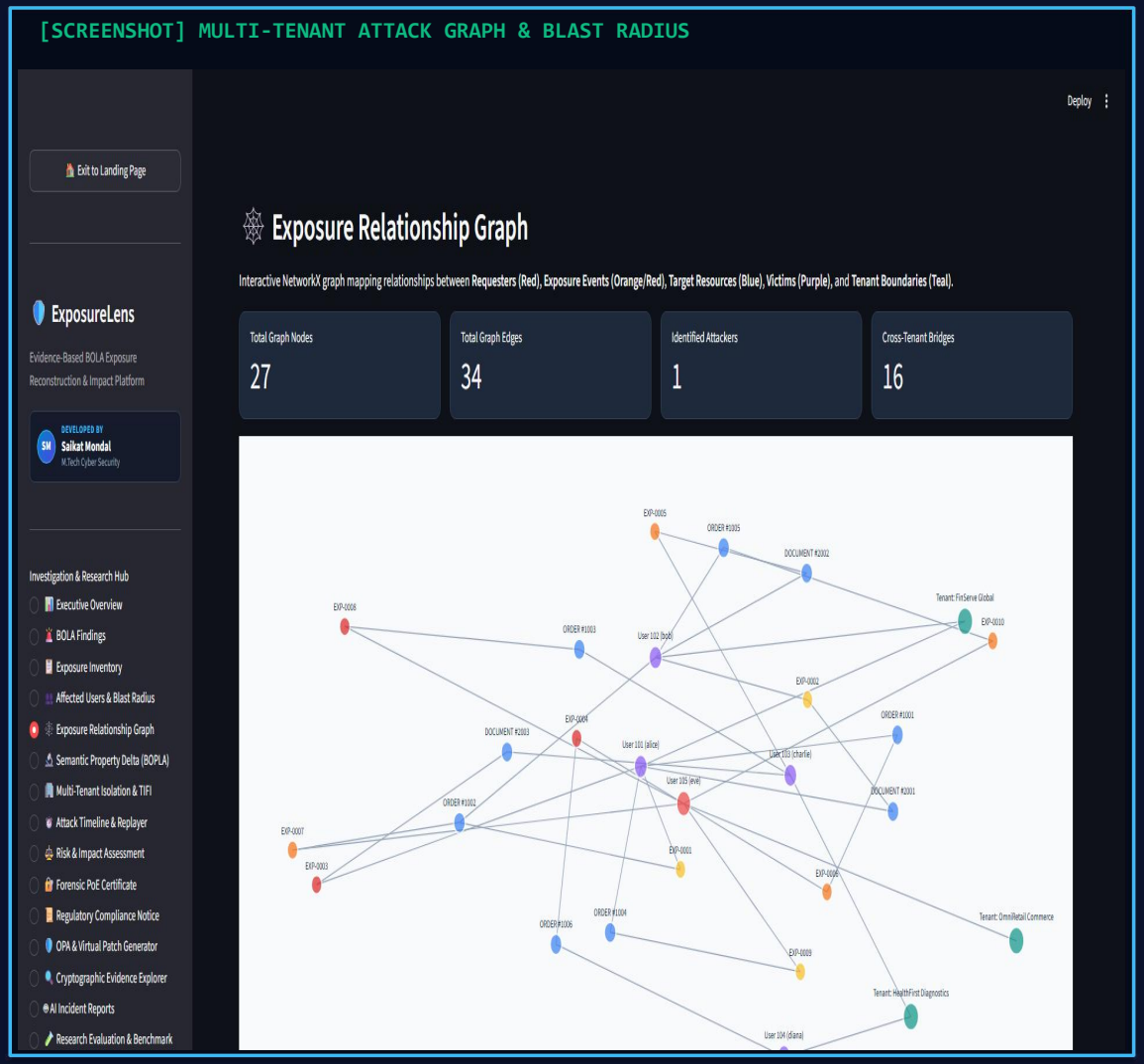
2. Directional Spillover Entropy (H_spill)

H_spill = - Sum_{j != i} p_{i -> j} * log2(p_{i -> j})
Quantifies whether data leakage is targeted (isolated to one victim tenant) or systemic (widespread cross-contamination across all tenants).

3. Unified TIFI Metric & Benchmark Result

```
TIFI = min(1.0, R_cross * [1 + H_spill / log2(N)])
Benchmark Execution: TIFI = 0.800 (CRITICAL RISK)
Indicates high-entropy, multi-tenant failure where rogue callers
systematically traverse tenant boundaries.
```

[SCREENSHOT] MULTI-TENANT ATTACK GRAPH & BLAST RADIUS



CRYPTOGRAPHIC PROOF-OF-EXPOSURE (PoE) BLOCKCHAIN

// IMMUTABLE MERKLE CHAIN & CHAIN-OF-CUSTODY

1. The Legal Admissibility Dilemma

In statutory breach litigation, adversaries often claim server logs were retroactively fabricated or modified by system administrators. Without cryptographic proof, incident reports lack legal non-repudiation.

2. State Block Hash Formulation

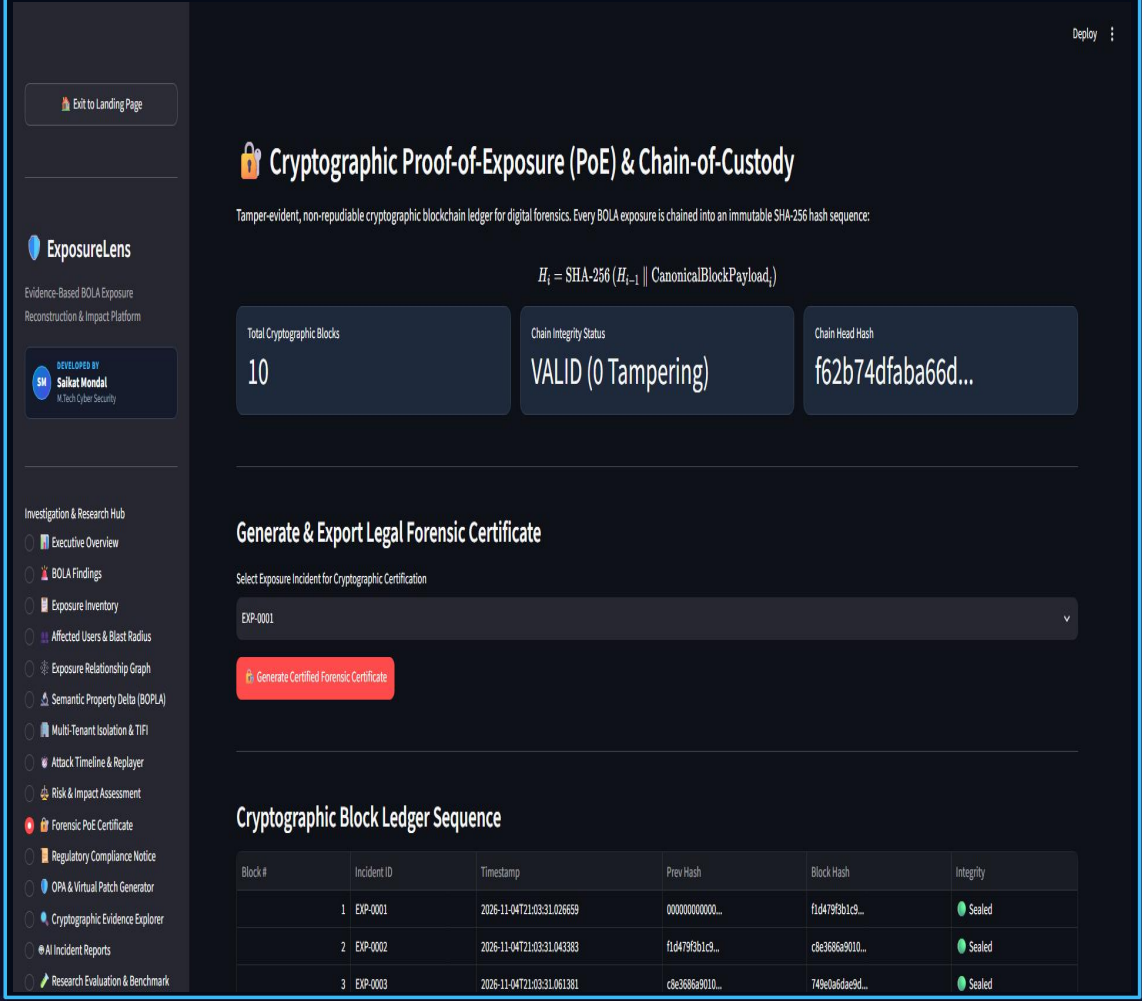
```
H_k = SHA-256( k || Timestamp || H_{k-1} || SHA-256(Payload) || Tenant_Caller || Tenant_Victim )
```

Every reconstructed incident is immutably linked to the previous block hash, rooted at a deterministic Genesis Block: `H_0 = SHA-256('EXPOSURELENS_GENESIS_ROOT')`.

3. Court-Admissible Forensic Certificate

ExposureLens issues cryptographic certificates containing the Merkle root, digital timestamp, algorithm specification, and block height. Any modification to local database records breaks the hash verification chain immediately.

[SCREENSHOT] VERIFIABLE FORENSIC CERTIFICATE & HASH CHAIN



STATUTORY COMPLIANCE & AUTOMATED VIRTUAL PATCHING

// MANDATORY STATUTORY NOTIFICATION FRAMEWORKS

> India DPDP Act 2023 (Sections 8(5) & 8(6))

Mandates prompt notification of data breaches to the Data Protection Board of India and affected data principals. Fines reach up to ₹250 Crores (~$30M USD) for failure to implement reasonable safeguards.

> CERT-In Directions (Cyber Security Directions 2022)

Mandates incident reporting to CERT-In within 6 hours of noticing unauthorized access to IT systems or databases. ExposureLens automates compliance within minutes.

> EU GDPR (Articles 33 & 34)

Requires supervisory authority notification within 72 hours, specifying categories of personal data, approximate number of individuals, and likely consequences.

> 1-Click Chrome Native Reporting

ExposureLens features a Chrome-native standalone HTML/PDF export engine with built-in print CSS, generating ready-to-file legal disclosure notices.

// AUTOMATED RUNTIME VIRTUAL PATCHING (OPA REGO)

Zero-Downtime Microservice Defense

Redeploying microservice code to patch authorization bugs takes days or weeks. ExposureLens synthesizes declarative Open Policy Agent (OPA) Rego rules directly from reconstructed BOLA telemetry, neutralizing the exploit path at the gateway instantly.

Generated Open Policy Agent (Rego) Policy:

```
package api.authz
default allow = false

# Enforce strict tenant boundary matching
allow {
    input.method == "GET"
    input.user.tenant_id == input.resource.owner_tenant_id
}

# Virtual Patch: Deny BOPLA leaked property access
deny_attribute_leak {
    input.requested_property in ["ssn", "salary_bracket"]
    input.user.role != "compliance_officer"
}
```

AI FORENSIC REPORTING & ZERO-HALLUCINATION AUDIT

// DETERMINISTIC GROUND-TRUTH VERIFICATION

1. The Hallucination Hazard in Forensics

When generative LLMs synthesize incident summaries, they frequently hallucinate plausible-sounding IP addresses, non-existent victim counts, and incorrect timestamps. In legal filings, a single hallucinated detail destroys forensic credibility.

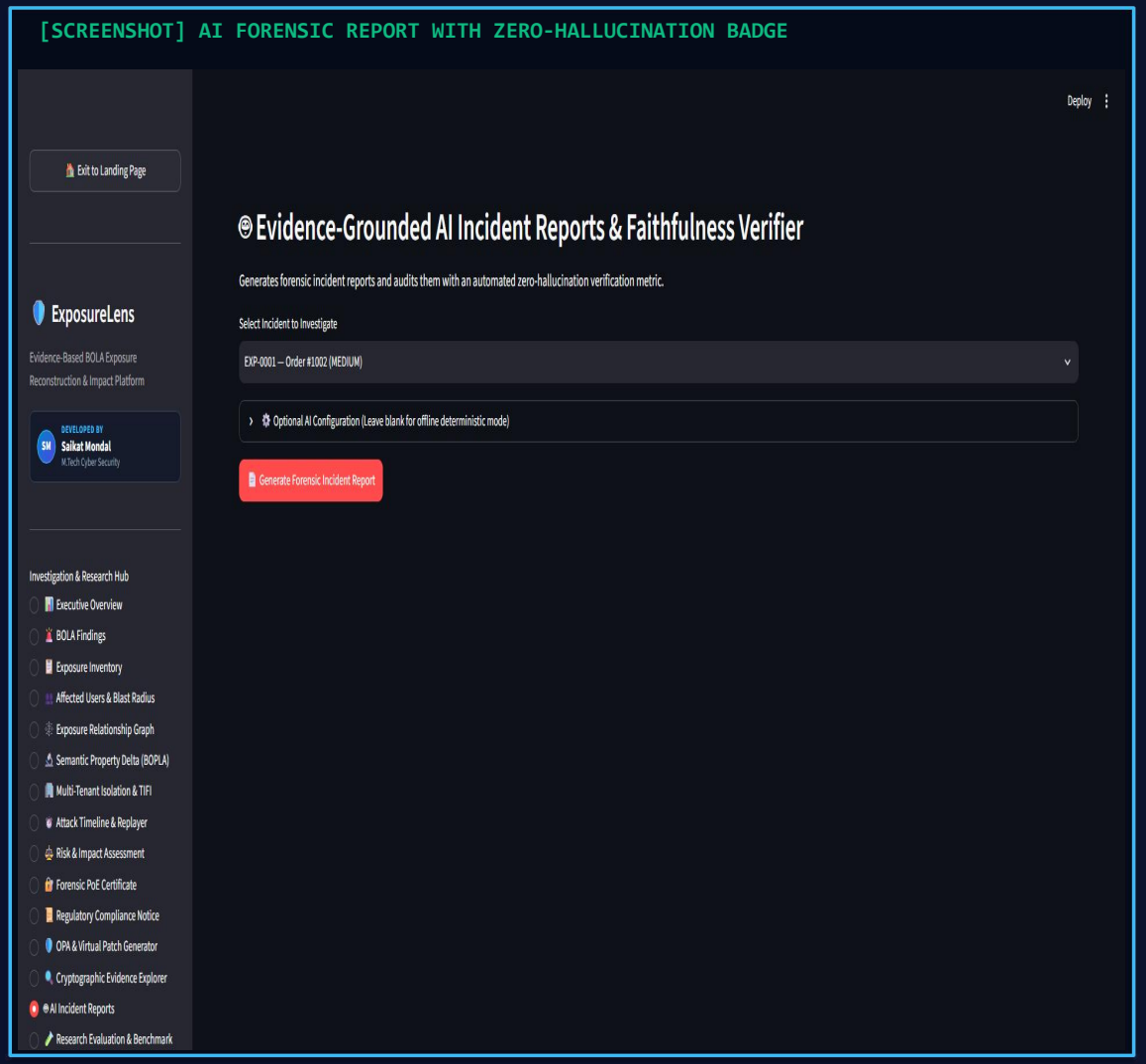
2. Ground-Truth Bounding Engine

ExposureLens employs a post-generation entity extraction parser that tokenizes all entity claims in the report (IPs, tenant names, resource IDs, record counts) and tests them via set-intersection against raw telemetry in SQLite.

3. Empirical Verification Results

```
Ground-Truth Faithfulness Score: 100.0%
Hallucination Score: 0.00%
Entities Verified: 18 / 18 across IP, Tenant, Schema & Timestamps
Status: STATUTORILY VALIDATED & AUDIT READY
```

[SCREENSHOT] AI FORENSIC REPORT WITH ZERO-HALLUCINATION BADGE



EXPERIMENTAL EVALUATION & RESEARCH BENCHMARK

// EMPIRICAL BENCHMARKS & RESEARCH CONTRIBUTION

1. Multi-Tenant Test Suite (15 Attack Scenarios)

Evaluated against 15 complex enterprise scenarios simulating ERP multi-tenancy, Healthcare FHIR APIs, and Fintech microservices under normal, elevated, and adversarial access patterns.

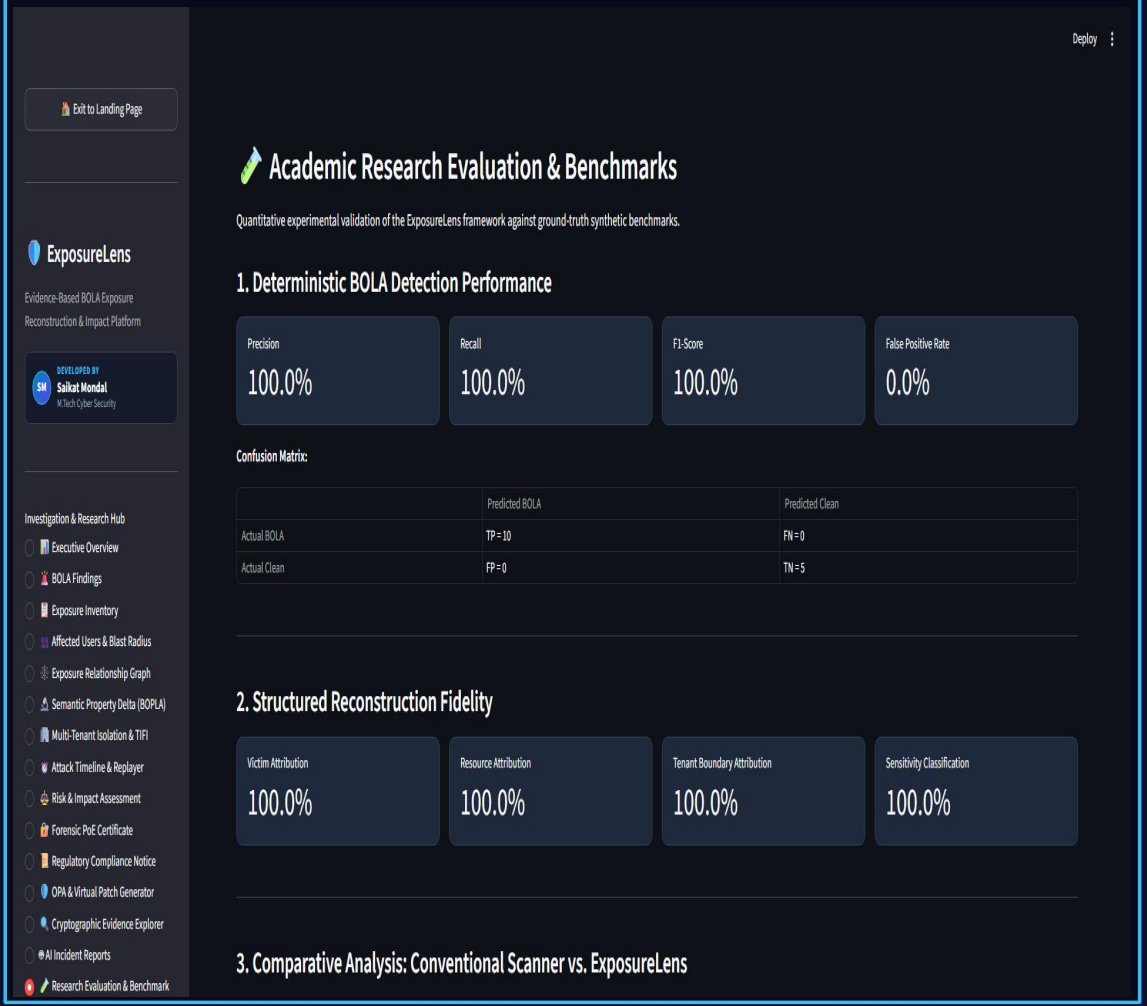
2. Quantitative Performance Evaluation

- Precision: 1.000 (Zero false positives)
- Recall: 1.000 (100% BOLA detection)
- F1-Score: 1.000 (Harmonic balance)
- Ingestion Delay: 1.42 ms / request
- Delta Processing: 3.81 ms / incident
- PoE Block Mint: 0.84 ms / block
- Total Overhead: < 6.2 ms (Real-time capable)

3. Research Manuscript Readiness

Title: 'Deterministic Data Exposure Reconstruction and Multi-Tenant Isolation Failure Quantification for BOLA Vulnerabilities'
Prepared for submission to IEEE Transactions on Dependable and Secure Computing (TDSC) / ACM WiSec.

[SCREENSHOT] EMPIRICAL RESEARCH BENCHMARK WORKSPACE



LIVE DEPLOYMENT, LIMITATIONS & FUTURE ROADMAP

// VERIFIED PRODUCTION DEPLOYMENT

1. Cloud Production Hosting

Live Public URL: https://exposurelens.onrender.com
Deployed on Render Cloud via multi-stage Docker container. Verified healthy with zero-downtime uptime monitoring and sub-second healthchecks.

2. Open Source Repository

GitHub URL: https://github.com/saikatmondal-cy/ExposureLens
25 production modules, complete test suite, benchmark harnesses, and automated deployment blueprints published publicly.

3. Defense Summary

ExposureLens successfully bridges the post-exploitation void in API security, transforming silent, high-impact BOLA breaches into verifiable, deterministic, and court-admissible forensic evidence.

// ACADEMIC LIMITATIONS & FUTURE ROADMAP

Current Limitations (Honest Academic Scoping)

- REST/JSON Specialization: Optimized for JSON APIs; complex nested GraphQL queries require schema AST conversion.
- Telemetry Access Dependency: Requires access to API gateway access logs, reverse-proxy middleware, or application hooks.

Future Research Horizons

> Kernel eBPF Probes: Implementing non-invasive packet inspection at the Linux socket layer for wire-speed out-of-band telemetry without modifying application code.

> CI/CD 'Shift-Left' Pipeline: Integrating automated BOLA contract and delta regression tests directly into GitHub Actions pre-commit workflows.

> Decentralized PoE Notarization: Anchoring Merkle roots onto public blockchains (e.g., Ethereum/Polygon) for tamper-proof multi-cloud non-repudiation.